

README - KIT COMPLETO DE ENCUESTA GQM+PRAGMATIC

Guía de Inicio Rápido para Implementación

Versión: 1.0 | **Fecha:** Enero 2026

Contexto: España | Indicadores Ciberseguridad-IA

Público Objetivo: CISOs, Security Leaders, Risk Managers

Idioma: Español



¿QUÉ CONTIENE ESTE KIT?

Tu kit completo de evaluación ciberseguridad-IA incluye **6 documentos profesionales** en formato Markdown (.md), listos para descargar e implementar:



Documentos Incluidos

#	Documento	Propósito	Usuarios	Tamaño
1	Marco Integrativo GQM+PRAGMATIC	Trazabilidad Objetivos – Métricas Técnicas	CISO, Risk Head	~40 pp
2	Matriz Evaluación PRAGMATIC Completa	Assessment tool (9 criterios × 9 indicadores)	Security Strategist	~35 pp
3	Mapeo Normativo (Preguntas – Regulaciones)	Alineación compliance (NIS2, EU AI Act, ISO)	Compliance Officer	~50 pp
4	Plantilla Excel IGM+ROI	Cálculos automáticos de madurez y retorno inversión	CFO, Finance Lead	~25 pp instrucciones
5	Plantilla PowerPoint Reporte Ejecutivo	Presentación Board & C-level (12 diapositivas key)	CISO, Executive Comms	~30 pp plantilla
6	README (este documento)	Quick-start guide & FAQ	Everyone	~20 pp

Total: ~200 páginas de contenido profesional, estructurado y listo para usar



QUICK START (5 PASOS)

Paso 1: DESCARGA (5 minutos)

Descargar los 6 archivos .md en tu máquina local:

```
/tu_carpeta_proyecto/  
├── 1_marco_gqm_pragmatic_ciberseguridad_es.md  
├── 2_matriz_pragmatic_completa_es.md  
├── 3_mapeo_normativo_preguntas_es.md  
├── 4_plantilla_excel_igm_roi_es.md  
├── 5_plantilla_powerpoint_reporte_es.md  
└── 6_README_kit_encuesta_es.md (este archivo)
```

Formato: UTF-8, Markdown (.md)

Tamaño Total: ~5MB

Compatibilidad: Windows, Mac, Linux

Paso 2: PREPARACIÓN (30 minutos)

2A. Selecciona Format Output

Cada archivo .md puede ser usado como:

-  **Markdown nativo** (copiar–pegar en herramientas)
-  **PDF** (usando pandoc, Print to PDF, o conversión online)
-  **Word** (copiar–pegar en MS Word, formatea automáticamente)
-  **Google Docs** (copiar–pegar en Google Docs)

Recomendación: PDF para distribución; Word para edición

2B. Crea tu Carpeta de Proyecto

```
Proyecto_Ciberseguridad_IA_2026/  
├── Documentos/  
│   ├── Marco_GQM_PRAGMATIC.pdf  
│   ├── Matriz_PRAGMATIC.pdf  
│   ├── Mapeo_Normativo.pdf  
│   └── README.md  
├── Herramientas/  
│   ├── Excel_IGM_ROI_2026.xlsx (descargado por ti)  
│   └── PowerPoint_Reporte.pptx (creado por ti)  
├── Datos/  
│   ├── Resultados_Assessment.xlsx  
│   └── Stakeholder_Feedback.md  
└── Entregas/  
    ├── Reporte_Ejecutivo.pdf  
    └── Roadmap_Implementacion.md
```

2C. Asigna Responsabilidades

Rol	Tarea	Entrega
CISO	Preparar stakeholders; autorizar presupuesto	Visto bueno
Risk Manager	Revisar mapeo normativo; compliance alignment	Validación regs
CTO	Evaluar viabilidad técnica; data sources	Confirmación factibilidad
CFO/Finance	Revisar presupuestos; ROI analysis	Aprobación inversión
Security Analyst	Ejecutar assessment; alimentar datos	Datos brutos

Paso 3: ASSESSMENT (3-5 SEMANAS)

Semana 1: Facilitated Interviews

Quién entrevistar (mandatorio):

- [] CISO o equivalente
- [] CTO/VP Infrastructure
- [] Risk/Compliance Head
- [] Vulnerability Management Lead
- [] Security Awareness Lead

Duración: 60-75 minutos por persona

Facilitador: External consultant o lead analyst (preferido: externo para objetividad)

Documentación: Utiliza "Matriz PRAGMATIC Completa" (Doc #2) como cuestionario

Guión Facilitador:

Bienvenida (5 min):

"Esta encuesta evalúa nuestra madurez ciberseguridad-IA
contra frameworks internacionales (NIS2, ISO 27001, EU AI Act).
No es auditoría punitiva; es diagnóstico para mejora estratégica."

Contexto (5 min):

Explicar 9 indicadores, escala GQM (0-5), PRAGMATIC criteria

Profundidad (50 min):

Por cada indicador:

1. Pregunta: "¿Dónde están ustedes hoy?"
2. Probe: Pedir evidencia (logs, tickets, policies)
3. Validate: Confirmar contra realidad operacional
4. Score: Asignar Nivel GQM (0-5)

Cierre (5 min):

"¿Gaps identificados? ¿Prioridades?"

Explicar: Resultados consolidados en 2-3 semanas

Semana 2-3: Data Aggregation & Analysis

Actividades:

1. Consolidar respuestas en Excel template (Doc #4)
2. Calcular IGM automáticamente
3. Generar ROI escenarios
4.
 Proyectar trajectory
5.
 Validación cruzada
6. Comparar percepciones stakeholders
7. Resolver divergencias >15 puntos
8.
 Triangular contra datos operacionales (SIEM, tickets)
9.
 Mapeo normativo
10. Para cada pregunta GQM, verificar alineación vs regulaciones (Doc #3)
11. Identificar gaps compliance específicos
12. Documentar plazos cumplimiento

Proyectar trajectory

Validación cruzada

Triangular contra datos operacionales (SIEM, tickets)

Mapeo normativo

Semana 4-5: Report Generation

13. Utilizar plantilla PowerPoint (Doc #5)
14. Customizar con datos del assessment
15. Agregar casos específicos organizacionales
16.
 - Priorizar recomendaciones
17.
 - Generar Reporte Ejecutivo 30-slide
18. Executive summary (IGM actual vs target)
19. Detailed findings (9 indicadores)
20. Roadmap (6 fases, presupuesto, ROI)
21. Board decisions required

Priorizar recomendaciones

Generar Reporte Ejecutivo 30-slide

Paso 4: PRESENTATION (1-2 SEMANAS)

4A. Rehearsal (Interno)

- [] Presentación CISO a leadership team (30 min)
- [] Feedback & ajustes
- [] Validar números/asunciones

4B. Executive Presentation

Estructura recomendada:

Audiencia: Board, CEO, CFO, CRO, CISO

Timeline:

- Intro (2 min): Contexto regulatorio (NIS2, EU AI Act)
- Current State (5 min): IGM 46/100; Level 2 (Repetible)
- Gaps & Risks (8 min): Top 3 críticos; financial impact
- Solution (10 min): 6-phase roadmap; €1.9M investment
- ROI (5 min): 11-month payback; €2M annual benefit
- Decisions (3 min): 5 board decisions required
- Q&A (12 min): Responder preguntas

Total: 45 minutos

4C. Decisiones Board

Recolectar firmas/aprobación para:

- [] Strategic priority (ciberseguridad-IA)
- [] Budget allocation (€1.9M Year 1)

- [] Governance restructuring (CISO→CEO)
- [] Risk appetite statement
- [] NIS2/EU AI Act timeline commitment

Paso 5: IMPLEMENTATION (6-18 MESES)

Phase-by-Phase Execution:

Fase	Indicadores	Timeline	Presupuesto	Hito Success
1	Governance	1 mes	€0	CISO reporting to CEO
2	1,2,4,5,8	2-3 mes	€1.2M	MTTD <24h; Coverage 80%+
3	Compliance	1-2 mes	€150K	NIS2 95% ready
4	Deepfake	1-2 mes	€500K	Pilot evaluation
5	Supply Chain	2-3 mes	€350K	SBOM 100%
6	Optimization	6+ mes	€400K	Portfolio IGM 85+

Utilizar Excel template (Doc #4) para tracking trimestral:

- Actualizar IGM scores monthly
- Re-baseline metrics quarterly
- Adjust roadmap based on learnings

CÓMO USAR CADA DOCUMENTO

Doc #1: Marco Integrativo GQM+PRAGMATIC

Cuándo usarlo:

- Primero: comprensión framework
- Después: referencia durante assessment (Q&A)
- Presentación: executive briefing

Cómo usarlo:

1. Lee Introducción (trazabilidad GQM jerárquica)
2. Estudia 9 Indicadores (estructura Goal→Question→Metric)
3. Valida PRAGMATIC scoring (evidence grids)
4. Referencia durante interviews

Preguntas típicas:

- "¿Por qué 9 indicadores específicamente?"
 - Respuesta: Cobertura holística (gobernanza, technical, compliance, human)
- "¿Cómo se alinean con NIS2?"
 - Respuesta: Mapeo normativo en Doc #3

Doc #2: Matriz PRAGMATIC Completa

Cuándo usarlo:

- Assessment execution (cuestionario)
- Scoring validation (criterios 1-9)
- Quality assurance (confirmación pragmaticidad)

Cómo usarlo:

1. Para cada indicador, valúa 9 criterios (1-5 scale)
2. Revisa ejemplos positivos/negativos en scoring table
3. Calcula average PRAGMATIC score
4. Compara contra benchmark (indicadores >4 = implementar inmediatamente)

Preguntas típicas:

- "¿Cuál es diferencia entre score 3 y 4 en criterion X?"
 - Respuesta: Ver tabla evaluación evidencia (operacional detail)

Doc #3: Mapeo Normativo

Cuándo usarlo:

- Compliance validation (asegurar alineación)
- Regulatory meeting prep
- Gap closure planning

Cómo usarlo:

1. Para cada pregunta GQM, revisar normativas mapeadas
2. Verificar plazo cumplimiento (¿ya vencido?)
3. Documentar gaps específicos vs requisitos
4. Priorizar remediation por deadline

Preguntas típicas:

- "¿Cuál es plazo NIS2?"
 - Respuesta: Agosto 2026 (6 meses); doc #3 muestra artículos específicos
- "¿Qué pasa si no cumplimos EU AI Act?"
 - Respuesta: Ver penalty section (Art.85); €€ o market access restriction

Doc #4: Plantilla Excel IGM+ROI

Cuándo usarlo:

- Post-assessment (alimentar datos brutos)
- Financial review (presupuesto approval)
- Monthly tracking (progress toward targets)

Cómo usarlo:

1. Descargar template (vacío)
2. Hoja "Raw Data Input": Entrar valores actuales

- M1.1 (Coverage %): 60%
- M1.2 (MTTD días): 50 días
- Etc.

3. Hoja "Dashboard": Fórmulas calculan automáticamente

- IGM scores
- ROI escenarios
- Payback periods

4. Hoja "Trajectory": Proyectar 18-24 meses

Formulas clave:

$IGM = (PRAGMATIC \times 0.4 + GQM_Level \times 20 + Compliance\% \times 0.3 + Deploy\% \times 0.1) / 1$
 $ROI\% = (Benefits - Investment) / Investment$
 $Payback = 12 / (Annual_Benefit / Investment)$

Preguntas típicas:

- "¿Cómo se calcula IGM?"
 - Respuesta: Formula ponderada en Doc #4; pesos justificados en métodos

Doc #5: Plantilla PowerPoint

Cuándo usarlo:

- Board presentation (~30 min)
- Executive steering committee updates
- Stakeholder alignment meetings

Cómo usarlo:

1. Descargar template (vacío)
2. Copiar estructura 12-slide principal
3. Customizar con tu data:
 - Slide 3: Tu IGM score (46) vs benchmark
 - Slide 4: Tu 9 indicadores con tus scores
 - Slide 8: Tu roadmap con tu presupuesto
 - Slide 9: Tu ROI escenarios (conservative/realistic/optimistic)
4. Agregar company branding, logos, color scheme
5. Ensayar 30 min; practicar Q&A

Recomendación: No leer slides; usa como visual support mientras hablas

Doc #6: README (Este documento)

Propósito: Guía de inicio rápido + FAQ

Secciones:

- Contents: Qué hay en kit
- Quick start: 5 pasos de implementación
- Document guide: Cómo usar cada doc

- FAQ: Preguntas comunes
- Troubleshooting: Problemas comunes & soluciones
- Timeline: Calendario realista

? FAQ (PREGUNTAS FRECUENTES)

F: ¿Cuánto tiempo toma completar assessment?

R: 3-5 semanas end-to-end

- Week 1: Stakeholder interviews (5 × 60 min)
- Week 2-3: Data aggregation, analysis, validation
- Week 4-5: Report generation, rehearsal
- Total: ~80-100 horas consultant time + organizational time

F: ¿Necesitamos consultant externo o puede ser interno?

R: Recomendación: **Híbrida**

- **Facilitator externo:** Credibilidad, objetividad (60% valor)
- **Team interno:** Conocimiento operacional, buy-in (40% valor)

Budget: Consultant 30 días × €400/día = ~€12K (1% of total investment)

F: ¿Qué pasa si nuestros scores son muy bajos?

R: Normal. La mayoría organizaciones están en Level 1-2 (20-50 IGM).

Interpretar como oportunidad, no fracaso:

- Baseline establecida ✓
- Roadmap claro ✓
- Investment ROI cuantificado ✓
- — Momentum para cambio

Recomendación: Comunicar al board como "diagnosis activa" (no crisis)

F: ¿Necesitamos implementar todos 9 indicadores simultáneamente?

R: No. Fases recomendadas:

- **Phase 1:** Governance (prerequisite; €0)
- **Phase 2:** 5 indicadores críticos (€1.2M)
- **Phase 3-5:** Compliance + secondary (€800K)

Timing: Distribuido 18 meses (no todo Year 1)

F: ¿Cuál es el ROI más probable?

R: Scenario "Realistic":

- Investment: €1.9M Year 1
- Benefits: €2M (2 incidents prevented + 20% MTTR reduction)

- Payback: 11 meses
- 3-year cumulative: €3.2M (110% ROI)

Rango: 26%-105% depending on breach probability assumptions

F: ¿Cómo escalamos a múltiples plantas/regiones?

R: Recomendación:

1. Pilot: 1 organización (3-5 weeks)
2. Scale: Replicate template a otras; customizar contexto local
3. Consolidation: Aggregate scores a portfolio level

Tiempo: +2-3 weeks por sitio adicional (after first pilot)

F: ¿Cómo se integra con ISO 27001, SOC 2, PCI-DSS assessments?

R: Este framework es **complementario** (no reemplaza):

- ISO 27001: Control framework (más granular)
- PCI-DSS: Industry-specific (pagos)
- **GQM+PRAGMATIC**: Strategic maturity + regulatory alignment (macro)

Utilizar GQM como "diagnostic herramienta" pre-audit; luego ISO detalles

F: ¿Qué hacer después del assessment?

R: Roadmap de 18+ meses:

Q1 2026: Assessment complete → Board approval (semanas 1-5)
Q2 2026: Phase 2 initiation → First indicators improving (semanas 6-13)
Q3 2026: Phase 3 → Compliance readiness checkpoint (semanas 14-26)
Q4 2026: Phase 4 → NIS2 deadline met; advanced initiatives starting
2027: Phases 5-6 → Portfolio IGM 76+ (Level 4)

TROUBLESHOOTING

Problema: "Stakeholders dan respuestas muy diferentes"

Solución:

1. Normalizar divergencias >15 puntos
2. Facilitar discussion (¿qué explica diferencia?)
3. Resolver via data: SIEM logs, tickets, audits (truth)
4. Document rationale; no promedio simple

Problema: "Excel formulas no calculan"

Solución:

1. Verificar formato números (sin €, %, etc.)
2. Revisar cell references (¿fórmula aún correcta?)
3. Cambiar format cell a "Number"
4. Copy-paste formula nuevamente si necesario

Problema: "Presupuesto rechazado por Finance"

Solución:

1. Reframe como "risk mitigation," no "IT capex"
2. Presentar realistically scenario (11-month payback)
3. Anclar vs cost of one breach (€500K-€2M)
4. Proponer phased: Phase 1 (€0), Phase 2 (€1.2M) con board approval

Problema: "NIS2 deadline is only 6 months away"

Solución:

1. Accelerate Phase 1+2 (compress 3 months → 6 weeks)
2. Hire temporary resources (contract analysts)
3. Prioritize NIS2-specific gaps (Compliance indicator)
4. Plan para compliance ≥95% by August 2026; optimization 2027



REFERENCIAS & RECURSOS

Documentos Normativos (Descargar)

- NIS2 Directive (EU Official Journal)
- EU AI Act (EU Official Journal)
- Plan Nacional Ciberseguridad (CNCS España)
- ISO 27001:2022 (ISO catalogue)

Herramientas Recomendadas

- Assessment facilitation: Miro, Mural (virtual whiteboarding)
- Data aggregation: Excel, Google Sheets, Airtable
- Reporting: PowerPoint, Google Slides, Figma
- Project tracking: Jira, Asana, Monday.com

Consultores/Partners

- INCIBE (Spain, NIS2 guidance)
- KPMG, Deloitte, PwC (assessments)
- Fortified (AI security)
- Darktrace (AI threat detection)



SOPORTE

¿Preguntas sobre contenido?

Framework questions: Revisar Doc #1 (Marco GQM+PRAGMATIC)

PRAGMATIC scoring: Revisar Doc #2 (Matriz Evaluación)

Regulatory alignment: Revisar Doc #3 (Mapeo Normativo)

¿Preguntas sobre implementación?

Excel setup: Ver Doc #4 (instructions + formulas)

Presentation: Ver Doc #5 (slide templates + notes)

Timeline: Este README (sección Roadmap)

Contacto para Soporte Especializado

Para consultoría hands-on:

Consorcio Seguridad Digital Spain

Email: assessments@ciberseguridad-ia.es

Tel: +34-XXX-XXX-XXXX

Servicios: Assessment facilitation, report customization,
roadmap execution, board coaching



CHECKLIST ANTES DE EMPEZAR

- ☐ Descargados los 6 documentos .md
- ☐ Convertidos a PDF o Word (para distribution)
- ☐ Creada carpeta proyecto local
- ☐ Designado project lead (típicamente CISO)
- ☐ Identificados 5 stakeholders clave para interviews
- ☐ Reservado facilitator (interno o externo)
- ☐ Confirmado presupuesto assessment (~ €12K consultant, opcional)
- ☐ Comunicado a board: "Assessment en progreso" (set expectations)
- ☐ Establecido calendario: Week 1 interviews, Week 4-5 reporte
- ☐ Preparada Sala/Conferencia virtual para facilitation



PRÓXIMOS PASOS

22. Hoy: Revisar este README completamente
23. Mañana: Compartir Marco GQM+PRAGMATIC (Doc #1) con CISO
24. Esta semana: Agendar kickoff meeting con stakeholders clave
25. Próxima semana: Iniciar interviews usando Matriz PRAGMATIC (Doc #2)
26. Semanas 2-3: Consolidar datos en Excel (Doc #4)
27. Semana 4: Generar reporte final con PowerPoint (Doc #5)
28. Semana 5: Presentar a Board; coleccionar decisiones

¡Buena suerte con tu assessment!

Kit desarrollado: Enero 2026 | Metodología: GQM + PRAGMATIC | Contexto: España NIS2/EU AI Act Compliance

FIN DE README